

API SECURITY ASSESSMENT



JSONPlaceholder Public Test API

Future Interns • Cyber Security Internship • Task 3

Prepared by Rahul Reghu Rajan

Project	Assessment Detail
Assessment type	Read-only API security review
Target	JSONPlaceholder public test API
Base URL	https://jsonplaceholder.typicode.com
Tool used	Postman
Evidence available	GET /users, GET /posts, GET /comments
Testing boundary	Public test data; no destructive activity

Postman-based assessment • Practical • Non-destructive

01 Executive Summary

This report documents a practical security review of selected JSONPlaceholder REST API resources. The assessment examines endpoint exposure, returned information, access requirements and the security controls that should be applied when the same API design is used with real business data.

Testing was performed in Postman using read-only GET requests. The captured evidence covers Users, Posts and Comments, with each request returning HTTP 200 OK and a structured JSON response.

The review focuses on public endpoint accessibility and the information exposed by user and comment resources. Authentication, authorization, rate limiting and input validation are included in the security-control review so the assessment maps directly to the Future Interns Task 3 requirements.

02 Assessment Context

Item	Details
Target	JSONPlaceholder
API type	Public mock / demonstration REST API
Protocol	HTTPS
Requests captured	GET only
Client	Postman
Purpose	Security learning and API response analysis

Important context: JSONPlaceholder is intentionally public and uses sample data. Therefore, public access observed during this exercise is not by itself evidence of a real-world compromise.

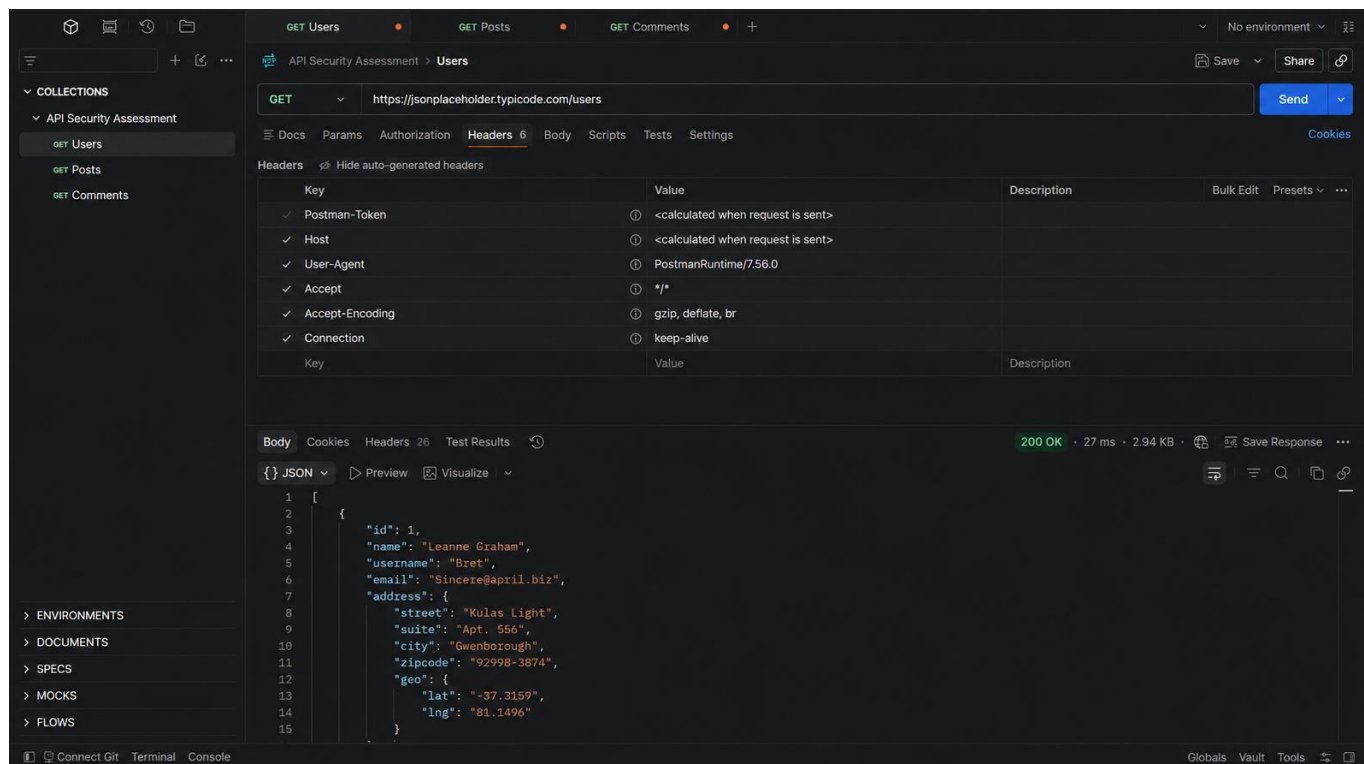
03 Assessment Questions

- What resources can be accessed through the selected endpoints?
- What information is returned to the client?
- Is authentication visibly required for the tested public resources?
- What security controls should protect equivalent production endpoints?
- Which observations can be supported directly by the captured evidence?

04 Evidence Review

The following observations are derived from the three Postman captures supplied for this assessment. The evidence is used as the basis for the security discussion rather than assuming behavior that was not tested.

Evidence	Request	Result	Security relevance
E-01	GET /users	200 OK	User profile fields returned
E-02	GET /posts	200 OK	Post records returned
E-03	GET /comments	200 OK	Comment records incl. name/email returned



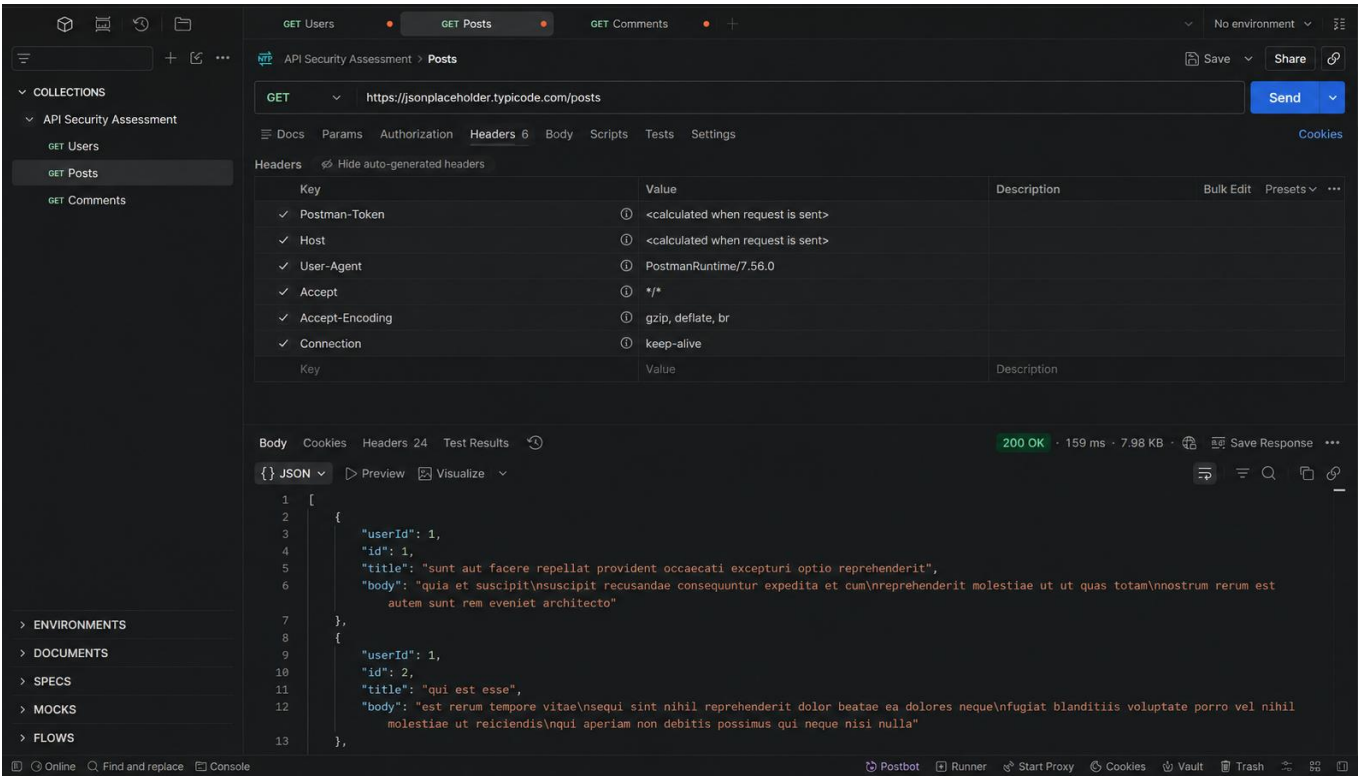
E-01

Observation 1 — Public resource accessibility

What the evidence shows: The three selected resources respond successfully without an Authorization header visible in the captured requests.

Why it matters: A similar pattern would be risky for a production API containing private records. An exposed endpoint can become a direct source of information for unauthorised users or automated collectors.

Recommended control: Use authentication for private resources and enforce authorization at the resource level. Public endpoints should be intentionally designed as public rather than becoming public by default.



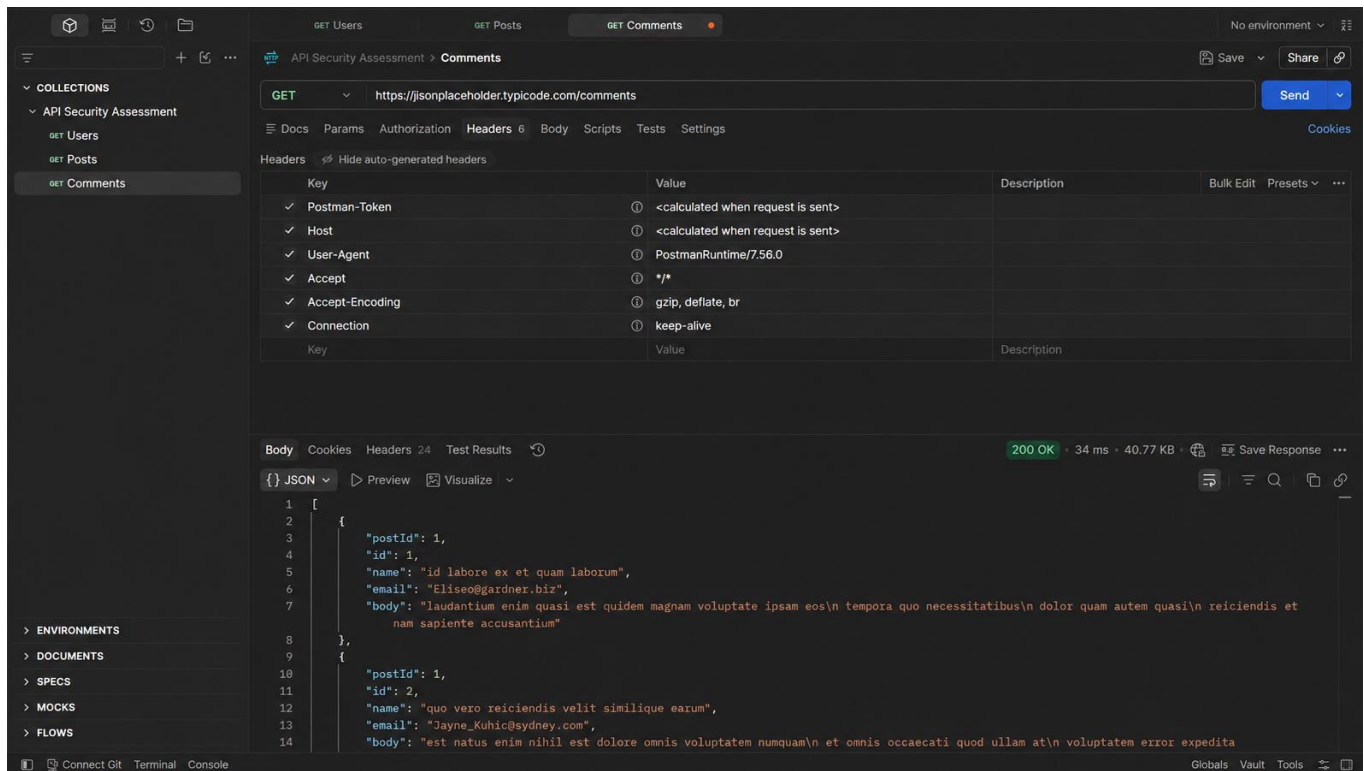
E-02

Observation 2 — Broad user response

What the evidence shows: The Users response contains multiple attributes for each record, including name, username, email, address, phone, website and company information.

Why it matters: Returning a larger object than the client needs increases the amount of information exposed if the API is reused with real personal data.

Recommended control: Apply data minimization and response shaping so clients receive only the fields required for their function.



E-03

Observation 3 — Contact-style information in comments

What the evidence shows: The Comments response contains name and email fields alongside comment content and identifiers.

Why it matters: In a real application, contact information exposed through broadly accessible endpoints can contribute to privacy concerns and automated collection.

Recommended control: Review each response field for business necessity and protect non-public fields through appropriate access controls.

05 Control Assessment

The assessment covers the security-control areas specified in the Future Interns task. The table distinguishes direct observations from controls that are recommended for a production API because the available evidence consists of read-only GET requests.

Control area	Current evidence	Assessment
Authentication	No Authorization header visible; GET requests succeed	Public access observed; production protection recommended
Authorization	No multi-user or role-based test performed	Not conclusively assessed
Data exposure	Users and Comments return several fields	Security consideration identified
Rate limiting	No rate-limit test evidence captured	Requires separate controlled test
Input validation	Only GET requests captured	Requires parameter/write-input test
HTTPS/TLS	API accessed through HTTPS URL	Transport encryption used
Error handling	No error-response evidence captured	Not conclusively assessed

Authentication & Authorization

The available screenshots support the observation that the selected public GET resources are accessible without an Authorization header. They do not establish whether an authenticated production system would properly enforce user- or role-level authorization. A production implementation should require authentication where data is private and verify authorization for every protected resource.

Rate Limiting

The captured GET responses do not provide sufficient evidence to confirm whether a rate limit is enforced. The appropriate security conclusion is that rate limiting must be verified and implemented for a production API. Controls should restrict excessive or automated requests and return an appropriate throttling response when limits are reached.

Input Validation

The captured requests do not include malformed parameters or write operations, so a validation weakness cannot be confirmed from the evidence. For production use, all client-controlled parameters and request bodies should be validated server-side for type, format, range and allowed values.

HTTPS / Transport

The tested API was accessed using an HTTPS base URL. HTTPS should remain mandatory for production APIs to protect credentials, tokens and application data while in transit.

06 Risk Register

ID	Risk theme	Severity	Basis
R-01	Public access to data resources	Medium*	Successful unauthenticated GET access
R-02	Excessive user information in response	Low–Medium*	Multiple profile fields returned
R-03	Contact information in comments response	Low–Medium*	Name and email fields returned
A-01	Authorization effectiveness	Advisory	Not tested beyond public access
A-02	Rate limiting	Advisory	No dedicated test evidence
A-03	Input validation	Advisory	No malformed/write request evidence

*Severity is a production-context estimate. JSONPlaceholder is a mock service with intentionally public sample data.

07 Remediation Priorities

Priority	Recommended action	Reason
1	Protect private API resources with authentication and authorization	Prevent unintended access to sensitive data
2	Reduce response fields to the minimum required	Limit privacy and information-exposure impact
3	Review contact information exposure	Avoid unnecessary personal-data disclosure
4	Implement rate limiting	Reduce scraping and request abuse
5	Validate all client-controlled input server-side	Prevent malformed or unsafe data from reaching application logic
6	Monitor API activity	Detect unusual access and abuse patterns

08 Evidence Inventory

File / Figure	Content	Use in report
GET_Users.png	Postman GET /users, 200 OK, JSON response	Supports R-01 and R-02
GET_Posts.png	Postman GET /posts, 200 OK, JSON response	Supports public endpoint observation
GET_Comments.png	Postman GET /comments, 200 OK, JSON response	Supports R-01 and R-03

09 Final Conclusion

The assessment demonstrates how a basic API security review can be performed using Postman and evidence-led analysis. The captured requests show that the selected JSONPlaceholder resources are publicly accessible and return structured data containing multiple fields.

The most relevant production lesson is that API exposure should be intentional: sensitive resources need strong authentication and authorization, responses should be minimized, and additional controls such as rate limiting, server-side validation and monitoring should be verified before deployment.

Because JSONPlaceholder is intentionally public and the evidence is limited to three GET requests, the report does not present unverified behavior as a confirmed vulnerability. Instead, the relevant controls are assessed and their production requirements are documented.

10 Scope, Limitations & Ethical Boundary

- Only the public JSONPlaceholder test API was considered.
- Testing was limited to read-only GET requests represented by the supplied evidence.
- No credentials were attacked or bypassed.
- No data was modified, deleted or exfiltrated.
- No denial-of-service or high-volume stress activity was performed.

This report is intended for the Future Interns Cyber Security Internship as an educational API security assessment.